

OWASP Risk → Control → Implementation → Component → Test Evidence

Reusable/centralized controls are marked **(shared)** and listed once with every OWASP risk they address, per the assignment's Rule 2. File paths are relative to backend/ unless stated otherwise.

A01:2021 — Broken Access Control

Control	Implementation	Component	Test Evidence
Role-required decorators (shared)	<code>security.role_required()</code> (session), <code>security.api_role_required()</code> (JWT)	Web, API	<code>tests/test_rbac.py::test_customer_cannot_create_product</code> , <code>::test_admin_only_user_admin_endpoints</code>
Role-scoped search/field visibility (shared)	<code>products.search()</code> , <code>products.visible_fields()</code> — one function decides rows+fields for all three interfaces	Web, API, Mobile (consumes API)	<code>tests/test_rbac.py::test_customer_search_hides_cost_and_inactive</code> , <code>::test_vendor_search_sees_only_own_inventory_with_cost_stock</code> , <code>::test_admin_search_sees_audit_fields</code>
Server-side ownership check (anti-IDOR) (shared)	<code>products._owns_or_admin()</code> re-derives ownership from the DB row, never trusts a client-supplied <code>vendor_id</code>	Web, API	<code>tests/test_rbac.py::test_vendor_cannot_edit_another_vendors_product</code> ; <code>docs/test-evidence/negative_authz_matrix.py</code> (25/25, incl. cross-vendor price/edit/delete attempts)
Registration cannot self-assign a privileged role	<code>auth_service.register_user()</code> hardcodes <code>role='customer'</code> ; role changes only via <code>users_admin.update_user</code> (admin-only)	Web, API	<code>tests/test_rbac.py::test_admin_only_user_admin_endpoints</code> ; <code>negative_authz_matrix.py</code>
Unauthenticated request rejected	<code>security.api_auth_required</code> returns 401 with no bearer token	API	<code>tests/test_rbac.py::test_no_bearer_token_is_unauthorized</code> ; <code>negative_authz_matrix.py</code>

A02:2021 — Cryptographic Failures

Control	Implementation	Component	Test Evidence
Password hashing (shared)	<code>security.hash_password/verify_password</code> (werkzeug PBKDF2)	Web, API	seeded users login correctly in every test; plaintext never stored (db.py schema has no plaintext password column)
MFA secret encrypted at rest	<code>security.encrypt_secret/decrypt_secret</code> (Fernet/AES-128-CBC+HMAC via cryptography), key from <code>LAB_ENC_KEY</code>	Web, API	<code>auth_service.start_mfa_enrollment</code> always stores <code>mfa_secret_enc</code> , never the raw secret
Mobile token storage encrypted at rest	<code>TokenStore</code> (<code>EncryptedSharedPreferences</code> ,	Mobile	<code>docs/scans/mobile/local_storage_check.txt</code>

Control	Implementation	Component	Test Evidence
	AES-256-GCM, Keystore-backed key)		
Transport encryption	SESSION_COOKIE_SECURE when LAB_HTTPS=1, HSTS header; mobile network_security_config.xml forbids cleartext in release + certificate pinning	Web, Mobile	docs/scans/mobile/mitm_pinning_test.txt
Dependency with known crypto CVEs upgraded	cryptography pin widened from <44.0 (vulnerable 43.0.3) to >=44.0.1	Backend	docs/scans/pip_audit_after_fix.txt ("No known vulnerabilities found")

A03:2021 — Injection

Control	Implementation	Component	Test Evidence
Parameterized SQL everywhere in the application (shared)	Every query in db.py/products.py/users_admin.py/auth_service.py binds ? params; like_escape() escapes LIKE metacharacters	Web, API	bandit_report.txt — 0 findings anywhere in the real application code

The original lab's deliberately-vulnerable injection demo pair (app.py::vulnerable_login/vulnerable_search, string-concatenated SQL) and its parameterized secure_login/secure_search counterpart — kept earlier in this project as a "before/after" teaching contrast — have been **removed entirely** (2026-09-23): the routes /login, /login-secure, /search, /search-secure are now 404 on the Web, and were never reachable via the API (api_*.py is a separate Flask blueprint that never routed through them). This does not weaken this control: the parameterized-query pattern above was always the actual protection for the real application; the removed pair was a redundant, deliberately-vulnerable demo that carried its own (deliberate) Bandit B608 findings, which are now gone rather than suppressed. See docs/scans/README.md for the full account.

A04:2021 — Insecure Design

Control	Implementation	Component	Test Evidence
Optimistic concurrency on price changes	products.update_price() — UPDATE ... WHERE id=? AND version=? inside BEGIN IMMEDIATE	Web, API, Mobile	docs/test-evidence/concurrency_price_race.py Test 1 — 1×200, 9×409 across 10 concurrent stale-version requests
Idempotency-Key required on price mutation	Same function; cached response replay for a repeated key	Web, API, Mobile	concurrency_price_race.py Test 2 — 10 concurrent identical-key requests apply the change exactly once
Graceful degradation under induced delay	db.connect(timeout=10) + WAL — a request queues behind a held write lock instead of corrupting/erroring	Backend	docs/test-evidence/resilience_induced_delay_output.txt
MFA mandatory by design, not configurable per-request	auth_service/api_auth.py always route through the pending-MFA stage regardless of login method	Web, API, Mobile	tests/test_mfa_and_google.py::test_password_only_login_cannot_reach_products

Control	Implementation	Component	Test Evidence
Ownership check returns 404, not 403, on mismatch (anti-enumeration) (shared)	products._owns_or_admin() callers (update_product_fields, soft_delete, and update_price as of this pass) all return not_found_or_forbidden/404 so a non-owning vendor can't distinguish "doesn't exist" from "isn't yours"	Web, API, Mobile	tests/test_price_protection.py::test_vendor_cannot_change_price_of_others_product; docs/test-evidence/negative_authz_matrix.py

A05:2021 — Security Misconfiguration

Control	Implementation	Component	Test Evidence
Security headers (shared)	app.py::set_security_headers — CSP (script-src 'none'), X-Frame-Options: DENY, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, HSTS when HTTPS, Server header removed	Web, API	manual curl -I against any route shows all headers
No debug mode / stack traces to users	app.run(debug=False); generic JSON {"error": ...} bodies, no tracebacks	API	api_products.py/api_admin.py never return exception text
Release mobile build not debuggable, minified	app/build.gradle.kts release block: isDebuggable=false, optimization { enable = true }, ProGuard rules	Mobile	docs/scans/mobile/apk_debuggable_check.txt
chattr invoked by resolved absolute path, not bare command	db._try_chattr_append_only uses shutil.which()	Backend	Bandit B607 no longer present in bandit_report.txt (was present before the fix)
Secrets never committed	.gitignore excludes backend/.env; .env.example ships instead	All	repo listing — no real secret file in the submission ZIP

A06:2021 — Vulnerable and Outdated Components

Control	Implementation	Component	Test Evidence
SBOM generation	docs/sbom/backend-sbom.json (real, tool-generated via pip-audit --format=cyclonedx-json, 32 components); docs/sbom/mobile-sbom.json (real, tool-generated via the CycloneDX Gradle plugin, 282 components — the full resolved dependency graph)	Backend, Mobile	files present in docs/sbom/
Dependency vulnerability scanning + remediation	pip-audit found 10 CVEs in cryptography==43.0.3; fixed by widening the version pin and upgrading	Backend	docs/scans/pip_audit_after_fix.txt

A07:2021 — Identification and Authentication Failures

Control	Implementation	Component	Test Evidence
Mandatory TOTP MFA (shared)	mfa.py (pyotp), auth_service.start_mfa_enrollment/confirm_mfa_enrollment/verify_mfa_login, gate enforced identically for password and Google login	Web, API, Mobile	tests/test_mfa_and_google.py (3 tests)
Account lockout after repeated failures (shared)	authenticate_password (5 failed logins → 5 min lock), verify_mfa_login (5 failed codes → 5 min lock)	Web, API	tests/test_mfa_and_google.py::test_wrong_mfa_code_is_rejected_and_locks_out_after_repeated_failures
Rate limiting on auth endpoints (shared)	Flask-Limiter, 5/min login, 10/min MFA, 10/hour register	Web, API	docs/test-evidence/rate_limiting_output.txt — 6th+ attempt in a minute gets 429
Google email_verified fail-closed (shared)	security.validate_google_userinfo rejects missing/false/non-boolean claim; same function used by Web callback and Mobile endpoint	Web, Mobile	tests/test_mfa_and_google.py::test_google_email_verified_missing_claim_is_rejected_fail_closed — regression test for the original .get("email_verified", True) bug
Independent mobile id_token verification	security.verify_google_id_token_mobile — signature/issuer/audience/expiry checked against Google's live public keys via google-auth, audience pinned to the mobile client id (Credential Manager, GoogleAuthConfig.kt)	Mobile	api_auth.py::google_mobile
Short-lived access tokens + refresh rotation	security.issue_access_token (15 min), rotate_refresh_token (revokes old jti, issues new pair)	API, Mobile	security.py::rotate_refresh_token
Password reset without user enumeration	auth_service.request_password_reset always responds identically whether or not the account exists	Web, API	code review of request_password_reset / password_reset_request route
No password reset over real email (synthetic-data rule)	mail.py writes to local mail_outbox/ file instead of SMTP	Backend	mail.py docstring; docs/test-evidence/
Negative-path authorization coverage across all three roles (shared)	Hand-written script actively tries denied operations (not just confirms allowed ones) with real issued tokens for customer/vendor/admin	Web, API, Mobile	docs/test-evidence/negative_auth_z_matrix.py — 25/25 checks passed

A08:2021 — Software and Data Integrity Failures

Control	Implementation	Component	Test Evidence
Tamper-evident audit log (shared)	db.log_event/verify_log_integrity — SHA-256 hash chain + append-only SQL triggers + append-only flat file	Web, API	tests/test_csrf_and_audit.py::test_audit_log_tamper_is_detected — direct row tampering (after

Control	Implementation	Component	Test Evidence
			dropping the trigger) is still caught by the hash chain
Idempotent, version-checked writes (also listed under A04)	products.update_price	Web, API, Mobile	concurrency_price_race.py
Release APK integrity	App must be signed (apksigner) before install; unsigned/tampered APKs are rejected by Android	Mobile	docs/scans/mobile/apk_debuggable_check.txt

A09:2021 — Security Logging and Monitoring Failures

Control	Implementation	Component	Test Evidence
Every security-relevant event logged (shared)	db.log_event calls throughout auth_service.py, products.py, users_admin.py, security.py (login success/fail, lockouts, MFA enroll/verify/fail, CSRF failures, access-denied, price changes/conflicts, user admin actions, rate-limit hits)	Web, API	/admin/users → /audit-log (web) or GET /api/v1/admin/audit-log shows the full trail
Integrity self-check surfaced to admins	verify_log_integrity() result shown at the top of the audit log page/endpoint	Web, API	templates.AUDIT_LOG_BODY; api_admin.py::audit_log

A10:2021 — Server-Side Request Forgery (SSRF)

Not applicable. No endpoint in this application accepts a URL and makes a server-side request to it (Google OAuth uses fixed, hardcoded Google endpoints via Authlib's OIDC discovery / google-auth's fixed JWKS endpoint — never a caller-supplied URL). Noted here explicitly rather than omitted, per the assignment's requirement to cover the OWASP list.

Mobile-specific (OWASP MASVS-aligned; not part of the Top 10 numbering but required by the assignment's mobile objective)

Control	Implementation	Test Evidence
No hardcoded secrets in the release APK	No Google client secret exists for the mobile OAuth client (Credential Manager has no client-secret concept, the same way PKCE removes it for authorization-code flows); API base URL is the only baked-in config	docs/scans/mobile/apk_secret_scan.txt
Insecure local storage prevention	TokenStore (EncryptedSharedPreferences) instead of plain SharedPreferences; allowBackup="false"	docs/scans/mobile/local_storage_check.txt
TLS enforcement + certificate pinning	Per-build-type network_security_config.xml — debug allows only 10.0.2.2 cleartext, release forbids all cleartext and pins the server's SPKI hash	docs/scans/mobile/mitm_pinning_test.txt (includes a substituted-certificate rejection test against the real release build)

Control	Implementation	Test Evidence
Release build hardening (no debug flags)	isDebuggable=false, R8 minify/shrink on, ProGuard rules kept minimal/specific	docs/scans/mobile/apk_debuggable_check.txt (also confirms R8 renamed the app's own classes)